Phase 2 Plan · HIPAA-ready clinic + mcp-ops-kit

mcp-ops-server · 20 Oct 2026 · branch plan-phase-2 · Planning only, no code · Part 7 starts after your merge and go

WHAT THIS PR DOES

- **Plans Phase 2** in comms/PLAN.md: the goal, an audience table, Parts 7-12 with acceptance criteria, and the key decisions. **STATUS.md** gets Phase 2 rows and a detailed Part 7 next action.
- **Adds rules to CLAUDE.md:** say HIPAA-ready, never HIPAA compliant; no real patient data ever; backend parity; each part updates the README audience and roadmap tables; automated PR reviewers (Bugbot, Cursor Security, Codex) are handled like Codex: reproduce, fix with a test or reply with reasons; no bot pushes or approves.
- **Broadens the README:** a wider intro, Who it's for, an honest file-by-file coupling map, Can I use it with real patient data? (not yet; code vs adopter duties, BAA with the LLM provider; not legal advice), and a Roadmap.

THE PARTS

Part	Builds	Done when
7 FHIR R4	Backend protocol; SQLite behind it; FhirBackend; seed as a FHIR Bundle	Same tests + eval gate pass on both backends, HAPI in CI; If-Match race test
8 Kit	A booking-business example first, then extract mcp-ops-kit	Both domains pass their eval gates on the kit
9 Safeguards	Audit log, OAuth 2.1 expiry/revocation, encryption at rest, data minimisation	Tamper test, no-restart revocation, no plaintext on disk, pinned field sets
10 Terraform	Blueprint on HIPAA-eligible AWS	fmt, validate, tflint, checkov in CI; never applied
11 Assurance	164.312 controls matrix, threat model, SECURITY.md, CodeQL, Dependabot, PyPI, signed images	Every control maps to code, a test, Terraform or the adopter
12 Evals at scale	Repeated live runs, pass^k, prompt-injection suite	Variance and injection results in the README, costs measured

WHY THIS WAY

- **HAPI, not a mock.** A mock agrees with my assumptions; a real FHIR server can disagree. Parity is enforced in CI because a second backend that drifts is worse than one backend.
- **Second domain before the kit.** Abstractions pulled from two working users fit; designed up front, they guess. Today only limits.py and the Dockerfile are domain-free (CI has one line of scopes).
- **HIPAA-ready, not compliant.** Compliance needs an organisation: BAAs (including the LLM provider), a risk analysis, policies. Code can supply the technical safeguards and say plainly what it cannot.

WHAT SURPRISED ME WHILE PLANNING

- The mcp 2.x SDK ships `httpx2`, not httpx, so the Part 7 plan names the client the repo already uses (no new dependency). The grader's step and precondition checks are already generic; only its patient-scope and appointments-state checks are clinic-coupled.

VERIFY IT YOURSELF

```
git diff --stat main     # docs + the brief generator only; no server code changed
ruff check . && ruff format --check . && pytest -q
grep -rn 'HIPAA compliant' README.md comms/      # only in 'never ... compliant' wording
```

INTERVIEW TALKING POINT

"Before writing code I mapped which files actually know the domain. Only two were free of it, so the kit gets extracted from two working domains, and I say HIPAA-ready, because compliance is not a property of a repo."

NEXT (YOUR ACTIONS)

1) Review and merge this PR. 2) Say **go** for Part 7 (branch part-7-fhir-backend). No Codex review needed for a planning-only PR unless you want one.